

Controls and Compliance Checklist

Botium Toys: Internal Security Audit

To complete the controls assessment, refer to the scope, goals, and risk assessment report and the control categories reference. An "X" in the Yes or No column answers: Does Botium Toys currently have this control in place?

Controls assessment checklist

Yes	No	Control	Explanation
	X	Least Privilege	All employees currently have access to internally stored data, including cardholder data and PII/SPII. Access needs to be restricted by role to reduce the impact of a breach or insider misuse.
	X	Disaster recovery plans	No disaster recovery plans are in place. These need to be implemented to ensure business continuity in the event of an incident or outage.
	X	Password policies	A policy exists but its requirements are nominal and below current minimum complexity standards (length, character variety), so it does not function as an effective control against credential-based attacks.
	X	Separation of duties	Not implemented. Without it, the same individuals may initiate and approve sensitive actions, increasing fraud risk and weakening overall access controls.
X		Firewall	The IT department maintains a firewall that blocks traffic based on an appropriately defined set of security rules.
	X	Intrusion detection system (IDS)	Not installed. The current stack is preventative only (firewall plus antivirus); an IDS would close the detection gap and surface anomalous activity.
	X	Backups	Critical data is not backed up. Combined with the absence of disaster recovery plans, this creates an unacceptable risk to business continuity.
X		Antivirus software	Installed and monitored regularly by the IT department, providing baseline malware detection and quarantine.
	X	Manual monitoring, maintenance, and intervention for legacy systems	Legacy systems are monitored, but there is no regular schedule and intervention procedures are unclear, so monitoring is inconsistent and cannot be relied on as a control.
	X	Encryption	Not in use. Sensitive customer data, including credit card information, is stored, processed, and transmitted in plaintext, exposing it to interception and unauthorized disclosure.
	X	Password management system	No centralized system exists to enforce password

Yes	No	Control	Explanation
			<i>policy or assist users with resets, which weakens policy enforcement and creates productivity overhead.</i>
X		Locks (offices, storefront, warehouse)	<i>The store, offices, and warehouse have sufficient physical locks restricting access to the premises.</i>
X		Closed-circuit television (CCTV) surveillance	<i>Up-to-date CCTV is installed and functioning across the physical location.</i>
X		Fire detection/prevention (fire alarm, sprinkler system, etc.)	<i>A functioning fire detection and prevention system is in place at the physical location.</i>

Compliance checklist

An "X" in the Yes or No column answers: Does Botium Toys currently adhere to this compliance best practice?

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice	Explanation
	X	Only authorized users have access to customers' credit card information.	<i>All employees currently have access to internal data, including cardholder data, violating the PCI DSS need-to-know principle.</i>
	X	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.	<i>Cardholder data is processed and stored locally without encryption and is broadly accessible across the workforce.</i>
	X	Implement data encryption procedures to better secure credit card transaction touchpoints and data.	<i>Encryption is not implemented at any of the credit card transaction touchpoints, exposing data both at rest and in transit.</i>
	X	Adopt secure password management policies.	<i>The existing password policy is nominal, and no password management system is in place to enforce or support it.</i>

General Data Protection Regulation (GDPR)

Yes	No	Best practice	Explanation
	X	E.U. customers' data is kept private/secured.	<i>Without encryption and with broad employee access to PII/SPII, E.U. customer data cannot be considered private or adequately secured.</i>
X		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.	<i>A documented plan exists to notify affected E.U. customers within 72 hours of a confirmed breach, meeting the GDPR Article 33 timeline.</i>
	X	Ensure data is properly classified and inventoried.	<i>Current assets have been inventoried but not classified by sensitivity. Without classification, the IT department cannot accurately prioritize protection or determine breach impact.</i>

Yes	No	Best practice	Explanation
X		Enforce privacy policies, procedures, and processes to properly document and maintain data.	Privacy policies, procedures, and processes have been developed and are enforced across the IT department and other employees.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice	Explanation
	X	User access policies are established.	Least privilege and separation of duties are not implemented, and all employees have access to all internally stored data. Effective user access policies are absent.
	X	Sensitive data (PII/SPII) is confidential/private.	Without encryption and with broad access to sensitive data, the confidentiality of PII/SPII cannot be assured.
X		Data integrity ensures the data is consistent, complete, accurate, and has been validated.	The IT department has integrated controls to ensure data is consistent, complete, accurate, and validated.
	X	Data is available to individuals authorized to access it.	While data is technically available, authorization is not appropriately scoped. The SOC criterion requires availability bounded by authorization, which is broken here.

Recommendations

The following recommendations are prioritised by the risk posed if not implemented in a timely manner. Highest-priority items address gaps that simultaneously affect PCI DSS, GDPR, and SOC obligations, where non-implementation creates the greatest financial, regulatory, and operational exposure.

- Implement encryption for credit card data and all PII/SPII, both in transit and at rest. This is the single most urgent gap because it cuts across PCI DSS, GDPR, and SOC compliance simultaneously, and the financial exposure from non-compliance fines is severe.
- Implement least privilege and separation of duties. Currently all employees have access to all internally stored data, including cardholder information and PII/SPII. Restricting access by role is foundational to PCI DSS and SOC user access requirements.
- Strengthen the password policy and deploy a password management system. The current nominal policy creates risk without giving the IT department a means to enforce it, and the absence of a management system slows productivity when resets are needed.
- Establish disaster recovery plans and routine backups of critical data. The complete absence of either creates a single point of failure for business continuity.
- Install an intrusion detection system (IDS) to complement the existing firewall and antivirus. The current stack is preventative only; adding detection closes a major visibility gap.
- Identify, classify, and inventory all assets. NIST CSF starts with Identify, and without classification the IT department cannot accurately assess loss impact or prioritise further controls.
- Establish a regular maintenance and intervention schedule for legacy systems. Monitoring exists, but the absence of a defined cadence and clear intervention methods leaves the door open to drift and undetected failures.